

2. Schriftliche Wiederholung **Konsolidierte Folien**

IT-SICHERHEIT / SEMESTER 1



1

01

Begriffe

2

Du kommst hier nicht rein



3

Authentisierung

- Die Authentisierung stellt den **Nachweis einer Person dar**, dass sie tatsächlich diejenige Person ist, die sie vorgibt zu sein.
- Eine Person legt also **Nachweise** vor, die ihre Identität bestätigen sollen.
- Je nach der eingesetzten Authentisierungsmethode kann die Person ihre Identität unter anderem auf folgenden Wegen behaupten:
 - sie hat **geheime Informationen**, die nur ihr bekannt sind (z.B. Passwort)
 - sie **besitzt einen Identifizierungsgegenstand** (z.B. Personalausweis)
 - sie **ist selbst das Identifizierungsobjekt** (z.B. biometrische Merkmale wie Fingerabdruck).
- Kurz gesagt: Die Authentisierung stellt einen ersten Schritt zur Prüfung der Identität dar, indem eine Person aktiv eine bestimmte Identität behauptet.

4

Beispiel für Authentisierung

- Ein Fußball-Fan, nennen wir ihn Thomas, möchte das EM-Finalspiel 2016 live im Stade de France in Paris mitverfolgen.
- Hierfür hat sich Thomas für viel Geld ein personalisiertes Ticket bei einem Veranstalter gekauft.
- Am 10.07 steht er in der Schlange, um in das Stadium reinzukommen und hofft, dass er sich sogar in die VIP-Loge durchmogeln kann.
- Am Stadioneingang werden die Besucher nicht nur geprüft, ob sie ein gültiges Ticket haben, sondern stichprobenartig auch, ob der auf dem Ticket aufgedruckte Namen mit dem Besucher übereinstimmt.
- Thomas wird auserwählt und muss nicht nur sein Ticket sondern auch sein Personalausweis vorzeigen.
- Mit dem Vorzeigen des Personalausweises behauptet er zunächst „Thomas“ zu sein.

5

Klassen von Authentifizierungsverfahren - WISSEN



- **Nachweis der Kenntnis von Wissen um die Echtheit eines Nutzers zu überprüfen.**
- **Beispiele:** Passwort, PIN, Antwort auf eine bestimmte Frage (Sicherheitsfrage) usw.

Charakteristika von Wissen:

- Das Wissen kann vergessen werden (insbesondere nach einer Feier).
- Das Wissen kann dupliziert, verteilt, weitergegeben und verraten werden.
- Das Wissen kann in vielen Fällen erraten werden (Social Engineering, Wörterbuchangriff ...).
- Das Wissen kann beim Eintippen mitgelesen oder mithilfe eines Keyloggers (Malware) im Endgerät ausgelesen werden.
- Einmal abgefangenes Wissen gilt als kompromittiert, wenn es auch für weitere Dienste genutzt wird.
- Die Preisgabe von Wissen kann kompromittiert werden (Androhung von Gewalt).
- Die Mitführung von Wissen erfordert in der Regel keine praktischen Hilfsmittel.

6

Klassen von Authentifizierungsverfahren - BESITZ



- **Verwendung eines Besitztums um die Echtheit eines Nutzers zu überprüfen.**
- **Beispiele:** Neuer Personalausweis (DE), SIM-Karte im Smartphone, Hardware-Sicherheitsmodule (Smartcard, USB-Stick, ...) usw.
- In der Regel wird der Besitz von geheimen Schlüsseln mithilfe von **Challenge-Response-Verfahren** nachgewiesen, die in den Sicherheitsmodulen sicher gespeichert sind.

Charakteristika von Besitz:

- Das Besitztum ist mit Kosten verbunden (Hardware).
- Das Besitztum muss mitgeführt werden (umständlich).
- Das Besitztum kann verloren gehen (kein Zugang mehr).
- Das Besitztum kann gestohlen werden (kein Zugang mehr).
- Das Besitztum kann übergeben oder weitergereicht werden (jemand anderes kann zugreifen).

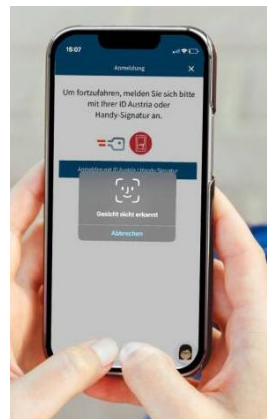
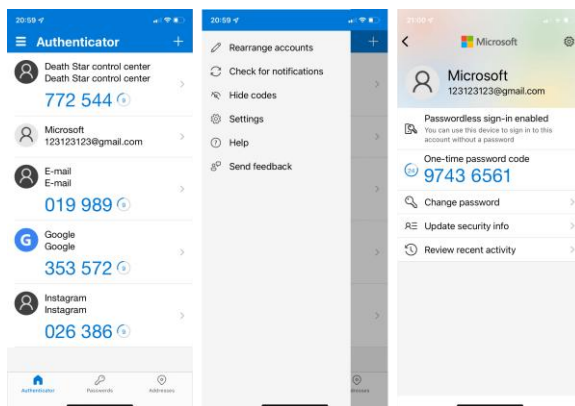
tgm [Quelle: <https://norbert-pohlmann.com/glossar-cyber-sicherheit/authentifikation/> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

7

7

Klassen von Authentifizierungsverfahren - BESITZ



tgm

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

8

8

Klassen von Authentifizierungsverfahren - SEIN

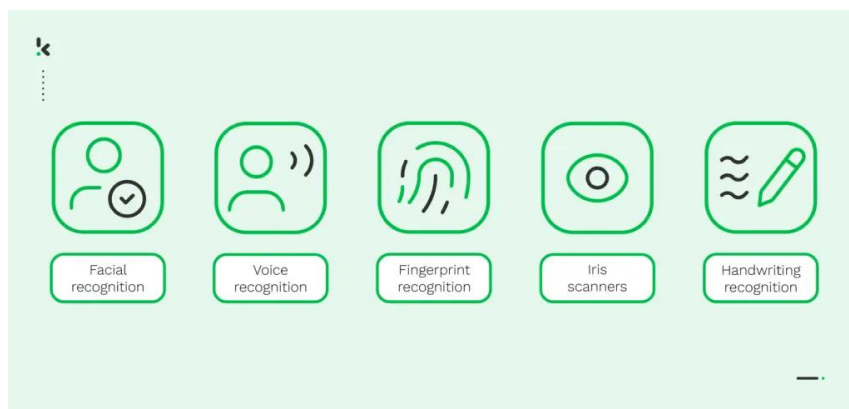


- **Gegenwart des Nutzers um die Echtheit eines Nutzers zu überprüfen.**
- **Beispiele:** Biometrische Merkmale wie Fingerabdruck, Gesichtsgeometrie, Iris, Tippverhalten, DNA usw.

Charakteristika von Sein:

- Biometrische Merkmale werden durch Personen immer mitgeführt.
- Biometrische Merkmale können nicht an andere Personen weitergegeben werden.
- Verfahren zu Erkennung von biometrischen Merkmalen können keine 100 %-Aussagen treffen, sondern nur mit einer gewissen Wahrscheinlichkeit die Echtheit von Personen abschätzen.
- Eine Lebenderkennung kann erforderlich sein (damit zum Beispiel ein künstlicher Fingerabdruck oder abgeschnittener Finger zurückgewiesen wird)
- Ein biometrisches Merkmal ist im Laufe der Zeit oder durch Unfälle veränderlich und damit schlechter erkennbar.
- Bestimmten Personengruppen fehlt das biometrische Merkmal.
- Ein biometrisches Merkmal kann nicht ersetzt werden (Problem, wenn diese „gestohlen“ werden können).

Klassen von Authentifizierungsverfahren - SEIN



Weitere unterstützende Faktoren



- **Beispiele:** Vergangene Transaktionen des Nutzers (Reputation), verwendete Endgeräte und Software des Nutzers (Technologie), Standort und Zeit des Authentisierungsprozesses.

Charakteristika weiterer unterstützender Faktoren:

- Die Reputation des Nutzers ist ein Indiz, wie er sich zukünftig verhalten wird.
- Die genutzte Technologie gibt einen Hinweis, ob es sich um den Nutzer handelt und wie das Angriffspotenzial des Endgeräts eingeschätzt werden kann.
- Der Standort gibt geografische und netzbasierte Informationen über das Vertrauensniveau des Orts (sichere oder unsichere Umgebung).

Authentifizierung

- Die Authentifizierung stellt eine **Prüfung der behaupteten Authentisierung** dar.
- Bei der Authentifizierung ist nun der Prüfer an der Reihe. Er überprüft die Angaben auf ihre Echtheit.
- Zeitlich betrachtet findet eine „Authentifizierung“ also nach einer „Authentisierung“ statt.

Beispiel für Authentifizierung

- Nachdem sich Thomas mit seinem Personalausweis authentisiert hat, überprüft und bestätigt nun der Sicherheitsdienst seine Identität.
- Der freundliche Sicherheitsmitarbeiter schaut sich den Personalausweis genau an, ob der vor ihm stehende Thomas dem Foto im Personalausweis entspricht.
- Die Überprüfung der Identität ist hier die Authentifizierung.
- Das Ergebnis der Authentifizierung ist hier: entweder Thomas kommt rein oder nicht.

Arten der Authentifizierung

- Bei der **Single-Factor-Authentifizierung (SFA)** wird ein Authentifizierungsfaktor benötigt, um die Identität eines Benutzers nachzuweisen. Die Angabe eines Benutzernamens und eines Passworts für die Anmeldung bei einer Social-Media-Website ist ein typisches Beispiel für SFA.
- Die **Multi-Faktor-Authentifizierung (MFA)** erfordert mindestens zwei Authentifizierungsfaktoren von zwei verschiedenen Typen, wie z. B. ein Passwort (Wissensfaktor) und einen Fingerabdruckscan (inhärenter Faktor).
- Die **Zwei-Faktor-Authentifizierung (2FA)** ist ein spezieller Typ der MFA, der genau zwei Faktoren erfordert. Die meisten Internetnutzer haben bereits Erfahrung mit der 2FA gemacht, z. B. wenn eine Banking-App sowohl ein Passwort als auch einen Einmalcode erfordert, der an das Telefon des Benutzers gesendet wird.
- **Passwortlose Authentifizierungsmethoden** verwenden keine Passwörter oder andere Wissensfaktoren. Systeme ohne Passwort sind als Schutz vor Datendiebstahl beliebt geworden, da die Wissensfaktoren am einfachsten zu stehlen sind.
- **Adaptive Authentifizierungssysteme nutzen künstliche Intelligenz und maschinelles Lernen**, um die Authentifizierungsanforderungen je nach Risikograd des Benutzerverhaltens anzupassen. Ein Benutzer, der beispielsweise versucht, auf vertrauliche Daten zuzugreifen, muss möglicherweise mehrere Authentifizierungsfaktoren angeben, bevor das System diese bestätigt.

Beispiele für die Authentifizierung

- Mit einem Fingerabdruckscan und einem PIN-Code wird ein Smartphone entsperrt.
- Vorlage eines Ausweises zur Eröffnung eines neuen Bankkontos.
- Ein Webbrowser überprüft die Legitimität einer Website, indem er ihr digitales Zertifikat überprüft.
- Eine App verifiziert sich gegenüber einer Programmierschnittstelle (API), indem sie bei jedem Aufruf ihren geheimen API-Schlüssel mitsendet.

Autorisierung

- Die Autorisierung ist die **Einräumung von speziellen Rechten**.
- War die Identifizierung einer Person erfolgreich, heißt es noch nicht automatisch, dass diese Person bereitgestellte Dienste und Leistungen nutzen darf.
- Darüber entscheidet die Autorisierung.

Beispiel für Autorisierung

- Der Sicherheitsmitarbeiter überprüft nun auch das Ticket von Thomas, um sicherzustellen, dass er im Besitz eines Tickets mit dem Zusatz VIP-Loge ist.
- Leider hat Thomas zwar ein gültiges Ticket für das Finalspiel jedoch keine Zusatzrechte, das Spiel in der VIP-Loge zu genießen.
- Er kommt zwar in das Stadion rein, ist aber nicht für den Besuch der VIP-Loge autorisiert.
- Hierfür fehlen ihm die zusätzlichen Rechte.



[Quelle: <https://www.dr-datenschutz.de/authentisierung-authentifizierung-und-autorisierung/> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

17

17

Beispiele für Autorisierung

- Wenn sich ein Benutzer bei seinem E-Mail-Konto anmeldet, kann er nur seine E-Mails sehen. Sie sind jedoch nicht berechtigt, die Nachrichten anderer Personen einzusehen.
- In einem Gesundheitsaktensystem können die Daten eines Patienten nur von Anbietern eingesehen werden, denen der Patient ausdrücklich seine Zustimmung erteilt hat.
- Ein Benutzer erstellt ein Dokument in einem gemeinsam genutzten Dateisystem. Sie setzen die Zugriffsberechtigungen auf „Nur lesen“, sodass andere Benutzer das Dokument zwar anzeigen, aber nicht bearbeiten können.
- Das Betriebssystem eines Laptops verhindert, dass ein unbekanntes Programm die Systemeinstellungen ändert.



[Quelle: <https://www.ibm.com/de-de/think/topics/authentication-vs-authorization> - letzter Abruf 07.09.2025]

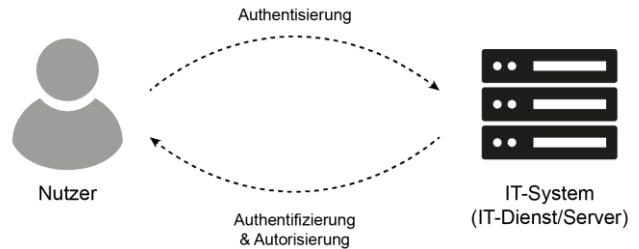
tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

18

18

Grundsätzliche Architektur der Identifikation und Authentifikation

- **Authentisierung** (Sichtweise Nutzer): Der Nutzer authentisiert sich gegenüber einem IT-System (Endgerät, Server, IT-Dienst, Cloud, ...), indem er einen Nachweis über seine digitale Identität, zum Beispiel den Nutzernamen, erbringt.
- **Authentifizierung** (Sichtweise IT-System): Das IT-System (Endgerät, Server, IT-Dienst, Cloud, ...) überprüft den Nachweis, um die Echtheit der digitalen Identität eines Nutzers im Rahmen der Authentifizierung festzustellen.
- **Autorisierung** (Sichtweise IT-System): Wenn die Echtheit der digitalen Identität eines Nutzers erfolgreich verifiziert werden konnte, kann das IT-System (Endgerät, Server, IT-Dienst, Cloud, ...) dem Nutzer definierte Rechte einräumen.
- **Erst wenn bekannt ist, wer auf ein IT-System zugreifen will, können die entsprechenden Rechte dieser Identität zugeordnet werden.**

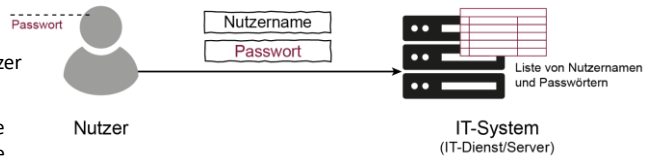


Generelle Authentifikationsverfahren

- Passwort-Verfahren
- Einmal-Passwort-Verfahren
- Challenge-Response-Verfahren
- Biometrische Verfahren

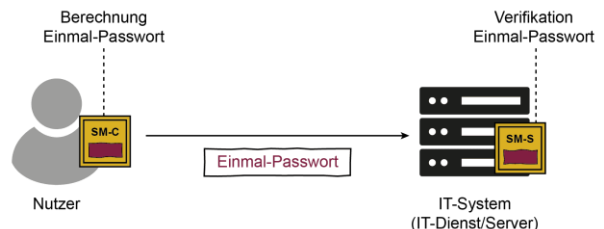
Passwort Verfahren

- Das **einfachste und prinzipiell unsicherste**, aber meist verwendete Authentifizierungsverfahren
- Nutzername und ein Passwort** werden zwischen dem Nutzer und dem IT-System im Vorfeld abgesprochen.
- Der Nutzer weist dann beim Zugriff auf das IT-System seine **Identität (Nutzername)** nach, indem er das abgesprochene Passwort sendet.
- Das Passwort-Verfahren ist eine Authentifikation mit dem Nachweis der **Kenntnis von Wissen** – des Passworts.
- Das IT-System hat dazu eine **Liste von Nutzernamen und Passwörtern** von allen zugreifenden Nutzern zur Verfügung, um den Nachweis des Wissens überprüfen zu können.



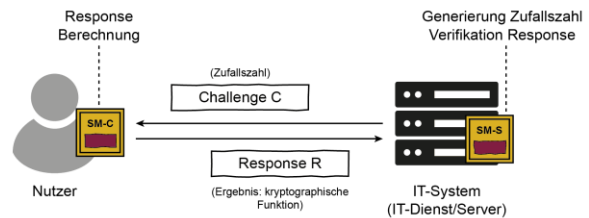
Einmal-Passwort Verfahren

- Passwort kann nur **einmal für eine Session** benutzt werden.
- Damit wird ausgeschlossen, dass ein Angreifer ein Passwort abhören und erneut verwenden kann (**Replay-Attacken**).
- Ein **Man-in-the-Middle-Angriff (MITM)** ist aber immer noch möglich.
- Die Einmal-Passwörter werden in der Regel in einem **Hardware-Sicherheitsmodul** des Nutzers generiert.
- Die Verifikation findet in einem Hardware-Sicherheitsmodul des IT-Systems statt.
- Das Einmal-Passwort ist **nur für eine bestimmte Zeit nach der Generierung gültig**.



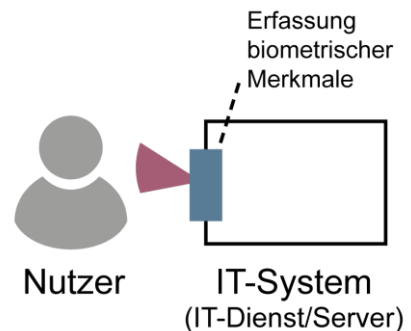
Challenge-Response-Verfahren

- Nutzer muss sich gegenüber dem IT-System **kryptografisch** beweisen muss.
- Bei diesem Verfahren besitzt der Nutzer ein **Geheimnis**, zum Beispiel einen geheimen Schlüssel, mit dem er als Beweis dafür, dass er den geheimen Schlüssel besitzt, spontan eine kryptografische Operation durchführen muss.
- In der Regel sendet das **IT-System dem Nutzer eine Zufallszahl**, die Challenge, die dann spontan kryptografisch verarbeitet und dem IT-System als Response gesendet wird.
- Das IT-System überprüft, ob der **Nutzer die kryptografische Operation richtig durchgeführt hat**.
- Aufgezeichnete Informationen können kein zweites Mal verwendet werden**, da immer neue Zufallszahlen als Challenge gesendet werden.
- Bei einer **Authentifizierung über unsichere Netze** müssen Challenge-Response-Verfahren eingesetzt werden, um ein Abhören und daraus resultierende missbräuchliche Verwendung zu verhindern.
- Für die Speicherung der geheimen Schlüssel und die Berechnung der kryptografischen Verfahren werden auf beiden Seiten **Hardware-Sicherheitsmodule** verwendet.



Biometrische Verfahren

- Authentifizierung **mittels biologischer Merkmale**.
- Biometrische Authentisierung verwendet **physiologische oder verhaltenstypische, also personengebundene Charakteristika**.
- Der prinzipielle Vorteil von biometrischen Verfahren für die Identifikation und Authentifizierung liegt darin, dass biometrische Merkmale **nicht unmittelbar gestohlen und im Allgemeinen nur schwer kopiert** werden können.
- Biometrische Merkmale können auf **viele Arten** gemessen werden z.B. Tippverhalten an einer Tastatur, die Fingergeometrie, das Fingerlängenverhältnis oder die Handgeometrie.
- Weitere Möglichkeiten sind Stimmanalyse, Gesichtserkennung, Erfassung der Unterschriftendynamik, des Netzhautmusters, des Iris-musters oder des genetischen Codes



02

Sichere Passwörter

25

IT-SICHERHEIT / SEMESTER 1 UND 2

Top 20 PRIVATE Passwörter in Deutschland 2024

Auswertung des Startups Identeco der Universität Bonn zeigt, wie unvorsichtig sich Viele im Internet verhalten

TOP 20 privater Passwörter in Deutschland 2024

Pos.	Passwort	Pos.	Passwort
1.	123456	11.	111111
2.	password	12.	123456a
3.	12345	13.	654321
4.	12345678	14.	1q2w3e4r5t
5.	abc123	15.	monkey
6.	123456789	16.	dragon
7.	1234567	17.	ashley
8.	qwerty	18.	princess
9.	iloveyou	19.	q1w2e3r4t5y6
10.	password1	20.	a123456

<https://identeco.de>

tgm [Quelle: <https://www.uni-bonn.de/de/neues/236-2024> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

26

26

Top 20 BERUFLICHE Passwörter in Deutschland 2024

#Manager Magazin: Was sind die beliebtesten Zugangsdaten der Dax-Angestellten zu ihren Accounts?

Position	Passwort		
1	[Varianten des Unternehmensnamens]	10	softwaremagazine
2	[Varianten von „linkedin“]	11	1234567
3	123456	12	123456789
4	password	13	sunshine
5	12345678	14	christian
6	liverpool	15	london
7	12345	16	Welcome1
8	111111	17	chelsea
9	Password1	18	d9189498
10	softwaremagazine	19	Martina
		20	research

tgm [Quelle: <https://www.uni-bonn.de/de/neues/236-2024> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

27

27

Hive Systems Password Table

- Hive Systems veröffentlicht jährlich ihre Password Table, die zeigt, wie lange es dauert, Passwörter unterschiedlicher Komplexität durch Brute-Force-Angriffe zu knacken.
- Für ihre Berechnungen 2025 nutzen sie zwölf Nvidia GeForce RTX 5090 GPUs – die derzeit leistungsstärksten Consumer-Grafikkarten.
- Als Grundlage dient der **bcrypt-Algorithmus** (beliebte Methode zum sichern von Passwörtern) mit Kostenfaktor 10, was 32.768 Iterationen entspricht.

Die Ergebnisse:

- Eine 8-stellige PIN (nur Ziffern): lediglich 15 Minuten
- 8 Zeichen mit Kleinbuchstaben: 3 Wochen
- 8 Zeichen mit Groß-/Kleinbuchstaben, Zahlen, Sonderzeichen: 165 Jahre
- 13 Zeichen mit vollem Zeichensatz: 56 Milliarden Jahre
- 14 Zeichen mit Sonderzeichen, Groß-/Kleinbuchstaben, Zahlen: 52 Milliarden Jahre

Die Zeit, die ein Hacker benötigt, um dein Passwort mittels einer Brute-Force-Angriffe zu ermitteln 2025

12 x RTX 5090 | bcrypt (10)

Passwortlänge (Zeichen)	nur Zahlen	nur Kleinbuchstaben	Klein- & Großbuchstaben	Zahlen und Klein-/Großbuchstaben	Zahlen, Klein-/Großbuchstaben, und Symbole
4	Sofort	Sofort	Sofort	Sofort	Sofort
5	Sofort	Sofort	57 Minuten	2 Stunden	4 Stunden
6	Sofort	46 Minuten	3 Tage	6 Tage	2 Wochen
7	Sofort	20 Stunden	4 Monate	1 Jahr	2 Jahre
8	Sofort	3 Wochen	15 Jahre	62 Jahre	164 Jahre
9	2 Stunden	2 Jahre	791 Jahre	36 Jahre	116 Jahre
10	1 Tag	40 Jahre	4% Jahre	238k Jahre	803k Jahre
11	1 Woche	1k Jahre	2 Mio. Jahre	14 Mio. Jahre	56 Mio. Jahre
12	3 Monate	27k Jahre	111 Mio. Jahre	817 Mio. Jahre	3 Mrd. Jahre
13	3 Jahre	705k Jahre	5 Mrd. Jahre	56 Mrd. Jahre	275 Mrd. Jahre
14	28 Jahre	18 Mio. Jahre	300 Mrd. Jahre	3 Bio. Jahre	19 Bio. Jahre
15	284 Jahre	477 Mio. Jahre	15 Bio. Jahre	218 Bio. Jahre	1 Bio. Jahre
16	2k Jahre	12 Mrd. Jahre	812 Bio. Jahre	13 Brd. Jahre	94 Brd. Jahre
17	28k Jahre	322 Mrd. Jahre	42 Brd. Jahre	840 Brd. Jahre	6 Trio. Jahre
18	284k Jahre	8 Bio. Jahre	2 Trio. Jahre	52 Trio. Jahre	463 Trio. Jahre

Hive Systems hivesystems.com/password

tgm [Quelle: <https://daher-gut-beraten.de/wie-schnell-wird-dein-passwort-geknackt-passwortsicherheit-im-jahr-2025/> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

28

28

Checkliste Sichere Passwörter - die wichtigsten Aspekte der Auswahl und Verwendung von Passwörtern

<https://pages.nist.gov/800-63-4/sp800-63b.html>

Weitere Erläuterungen und Zusammenfassung:

<https://specopsssoft.com/de/blog/nist-passwortrichtlinien-vollstaendiger-leitfaden-zur-nist-passwortkonformitaet/>

1.2. Document Structure

This document is organized as follows. Each section is labeled as either normative (i.e., mandatory for compliance mandatory).

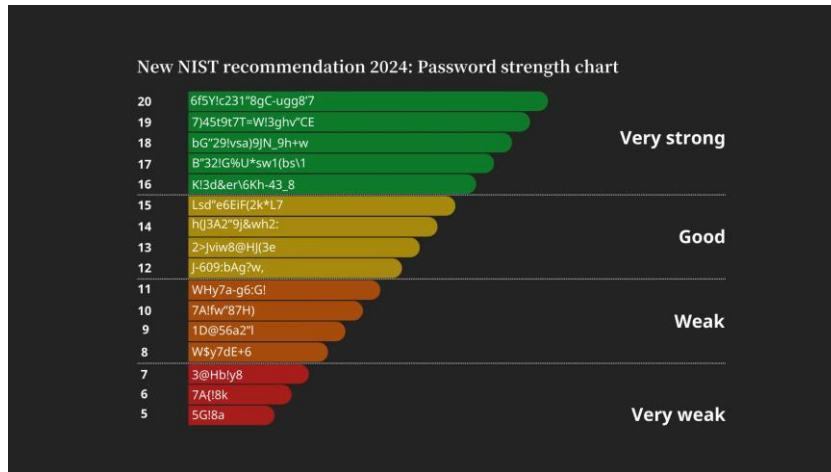
- Section 1 introduces the document. This section is *informative*.
- Section 2 describes requirements for AALs. This section is *normative*.
- Section 3 describes authenticator and verifier requirements. This section is *normative*.
- Section 4 describes requirements for authenticator event management. This section is *normative*.
- Section 5 describes requirements for session management. This section is *normative*.
- Section 6 provides security considerations. This section is *informative*.
- Section 7 provides privacy considerations. This section is *informative*.
- Section 8 provides customer experience considerations. This section is *informative*.
- The References section lists publications that are cited in this document. This section is *informative*.
- Appendix A discusses the strength of passwords. This appendix is *informative*.
- Appendix B discusses syncable authenticators. This appendix is *normative*.
- Appendix C contains a selected list of abbreviations used in this document. This appendix is *informative*.
- Appendix D contains a glossary of selected terms used in this document. This appendix is *informative*.
- Appendix E contains a summarized list of changes in this document's history. This appendix is *informative*.

2. Authentication Assurance Levels

Kernpunkte der NIST-Passwortregeln (Zusammenfassung)

1. MUSS mindestens 8 Stellen haben.
2. SOLLTE mindestens 15 Stellen haben.
3. SOLLTE möglich sein mind. 64 stellige Kennwörter zu erstellen.
4. SOLLTE ASCII Zeichensatz erlaubt sein.
5. SOLLTE Unicode Zeichensatz erlaubt sein.
6. KEINE Mischung von verschiedenen Zeichentypen auferlegen.
7. KEINE periodische Änderung der Passwörter.
8. KEINE Sicherheitsfragen für Zugänge um das Passwort zu umgehen.
9. MUSS bei Änderung oder Erstellung gegen Passwortlisten (Blocklists) abgeprüft werden (bei Fund darf dieses Passwort nicht verwendet werden und muss ein neues definiert werden).
10. MUSS eine Meldung (bei Blocklist-Fund) wiedergegeben werden warum das Passwort nicht verwendet werden kann.
11. MUSS Limitierung der Anmeldeversuche integriert werden.
12. MUSS bei Änderung und Erstellung über einen verschlüsselten Kanal übertragen werden.
13. MUSS erlaubt sein einen Passwort-Manager zu verwenden und die Copy-Paste Funktion zu benutzen.
14. MUSS das komplette Passwort verifiziert werden (in einigen Fällen werden Passwörter nur bis zu einer gewissen Stelle überprüft, alles was danach kommt wird abgeschnitten)

Stärke der Kennwörter entsprechend NIST Klassifizierung



Kernpunkte der NIST-Passwortregeln

- Länge statt Komplexität:** Statt fester Regeln für Sonderzeichen und Großbuchstaben wird eine Mindestlänge von 15 Zeichen empfohlen, wobei längere Passphrasen noch besser sind.
- Passphrasen nutzen:** Ermutigen Sie die Nutzer, lange, aber einprägsame Sätze als Passwort zu erstellen, z. B. "Ich fahre gerne mit dem roten Fahrrad durch die Stadt".
- Regelmäßige Passwortänderungen abschaffen:** Stattdessen sollten Passwörter nur bei Verdacht auf Kompromittierung oder auf Nutzeranfrage geändert werden.
- Blocklisten für Passwörter:** Jedes neue Passwort muss gegen eine Datenbank bekannter und kompromittierter Passwörter geprüft werden.
- Unterstützung von Passwort-Managern:** Die Verwendung von Passwort-Managern und Auto-Fill-Funktionen wird gefördert.
- Sicherheitsfragen verbieten:** Die Nutzung von Sicherheitsfragen wird nicht mehr empfohlen, da sie ein erhebliches Sicherheitsrisiko

darstellen.

- Passwort-Verifizierung:** Systeme müssen das vollständige Passwort verifizieren und dürfen es nicht nach einer bestimmten Zeichenanzahl abschneiden.

Warum die Änderungen?

- Vermeidung vorhersehbarer Muster:** Regelmäßige Passwortkomplexitätsregeln (z.B. Password!1) führen oft zu einfachen, vorhersehbaren Mustern, die von Angreifern leicht geknackt werden können.
- Bessere Benutzerfreundlichkeit:** Langen Passphrasen sind leichter zu merken, was die Wahrscheinlichkeit verringert, dass Benutzer Passwörter aufschreiben oder sie wiederverwenden.
- Erfolgreichere Angriffe:** Moderne Angriffe sind sehr schnell und können Millionen von Kombinationen pro Sekunde durchprobieren. Lange Passphrasen erhöhen die Zeit und die Kosten für das Knacken erheblich.

Weitere Gedanken ...

- Passwörter **speichern** ...
- Passwörter **ändern**, wann und wie oft ...
- Passwörter an Menschen **weitergeben** ...
- **Alternativen** für Passwörter finden ...

03

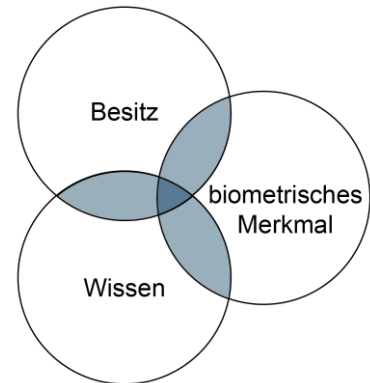
Multifaktor-Authentifizierung

Multifaktor-Authentifizierung

- Stand der Technik heute ist die Multifaktor-Authentifizierung.
- Mit einer Multifaktor-Authentifizierung (MFA) kann flexible agiert und mit einer höheren Vertrauenswürdigkeit authentifiziert werden.

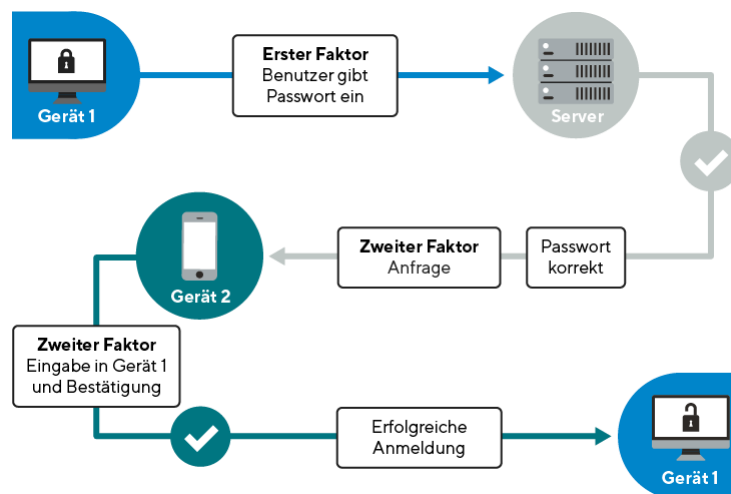
Beispiel Multifaktor-Authentifizierung:

- Es wird als **Basis eine digitale Signatur** einer Zufallszahl mithilfe eines Hardware-Sicherheitsmoduls (Smartcard, USB-Sick, ...) umgesetzt, das mit einem Passwort oder PIN aktiviert werden muss.
- Um den Nutzerbezug zu verstärken, muss der Nutzer noch mithilfe eines **Fingerabdrucks oder Gesichtserkennung seine Gegenwärtigkeit** zusätzlich verifizieren lassen.



35

So funktioniert die Zwei-Faktor Authentifizierung



36

Multifaktor-Authentifizierung

- Multifaktor-Authentifizierungsverfahren sind **verhältnismäßig einfach zu implementieren** und erhöhen die Hürden für Angriffe massiv.
- Zunehmend **Standard** in der Geschäftswelt.

Beispiel:

- Microsoft hat im November 2023 neue Richtlinien für Unternehmenskunden eingeführt und Unternehmensaccounts standardmäßig auf MFA umgestellt.
- Laut einer Studie von Cisco ist die Anwendung von MFA im letzten Jahr weltweit um 41 Prozent gestiegen.
- In Deutschland lag der Zuwachs sogar bei 52,3 Prozent.



Welche MFA-Verfahren sich für die Implementierung anbieten



Authentifizierungs-Apps

Apps wie der Microsoft Authenticator und der Google Authenticator generieren zeitbasierte Einmalpasswörter (engl. Time-based one-time password, kurz: TOTP), die beispielsweise ergänzend zu der klassischen Kombination aus Nutzernamen und Passwort eingesetzt werden können. Die App von Microsoft unterstützt außerdem auch Push-Benachrichtigungen und Biometrie. User müssen ein Smartphone zur Hand haben, um solche Authenticator-Apps zu nutzen.



SMS-Authentifizierung

Bei der SMS-Authentifizierung schickt das System an den Nutzer zur Anmeldung eine einmalige Bestätigungsnummer – die SMS TAN bzw. PIN. Erst nach Eingabe des erhaltenen Codes ist die Anmeldung abgeschlossen. Das Verfahren ist einfach und weit verbreitet, kann jedoch aus der Ferne kompromittiert werden und ist weniger sicher als der Einsatz von Authenticator-Apps und FIDO2.



FIDO2 Key

FIDO steht für Fast Identity Online und ist ein offener Standard für sichere Authentifizierung im Internet. Ein FIDO2-Schlüssel ist ein physisches Gerät – meist in Form eines Schlüsselanhängers. Die Token sind für weniger als 30 Euro erhältlich. FIDO2 kann die gängige Benutzernamen-Passwort-Anmeldung um einen weiteren Faktor mit dem FIDO2-Token ergänzen und auch für eine komplett passwortlose Anmeldung eingesetzt werden.

Wo kommen diese Sicherheitsverfahren zum Einsatz?

- **Online-Banking:** Anmeldung mit Passwort und Bestätigung von Transaktionen zusätzlich mit TAN via mTAN oder pushTAN, alternativ auch kartenbasierte Systeme wie chipTAN oder HBCI.
- **Debit- oder Kreditkartenzahlung:** Der Chip in der Karte zeigt den Besitz an und das Wissen der PIN legitimiert den Vorgang.
- **Online-Ausweisfunktion des Personalausweises (DE):** Zur Datenübermittlung muss der Chip im Ausweis durch Eingabe der PIN zunächst freigegeben werden. Zusätzlich findet eine gegenseitige Authentisierung zwischen Ausweis und Diensteanbieter statt und die ausgelesenen Daten werden Ende-zu-Ende-verschlüsselt zum Diensteanbieter übertragen.
- **Cloud- oder E-Mail-Anbieter, Social Media Plattformen:** Sicherer Login mit Passwort und mTAN oder einem OTP aus einer Authenticator-App, alternativ auch hardwarebasiert mit einem U2F/FIDO-Token.
- **Steuererklärung:** Mit finanzonline kann die Steuererklärung digital eingereicht werden, die Anmeldung erfolgt mit der ID-Austria.
- ...

Bitte nicht: Die Zwei-Faktor-Authentisierung deaktivieren

- Einen Online-Account ausreichend abzusichern, ist manchmal unbequem.
- In jedem Fall ist davon abzuraten, die Zwei-Faktor-Authentisierung zu deaktivieren.
- **Sobald dies bei einem Online-Dienst möglich ist, sollte man sie anwenden.**
- Gerade beim Online-Banking, dem Online-Shopping und bei Accounts mit weitreichenden Rechten und Möglichkeiten (z.B. E-Mail und Social Media) lohnt sich das Mehr an Sicherheit.
- Identitätsdiebstahl, fremde Accountübernahmen oder die Veröffentlichung sensibler Daten müssen also nicht sein.

Aktuelle Empfehlungen und Risiken

Empfehlungen

- Wenden Sie eine Zwei-Faktor-Authentisierung an, sobald ein Online-Dienst dies ermöglicht.
- Viele Dienste haben die Funktion standardmäßig deaktiviert, bieten sie aber dennoch an. Eine Überprüfung der Login-Verfahren lohnt sich.
- Gelangt Ihr Passwort oder Ihre PIN in die falschen Hände, sind Ihre sensiblen Daten dennoch gut gesichert, wenn sie durch die weitere Barriere eines zweiten Faktors vor fremdem Zugriff abgeschirmt werden.

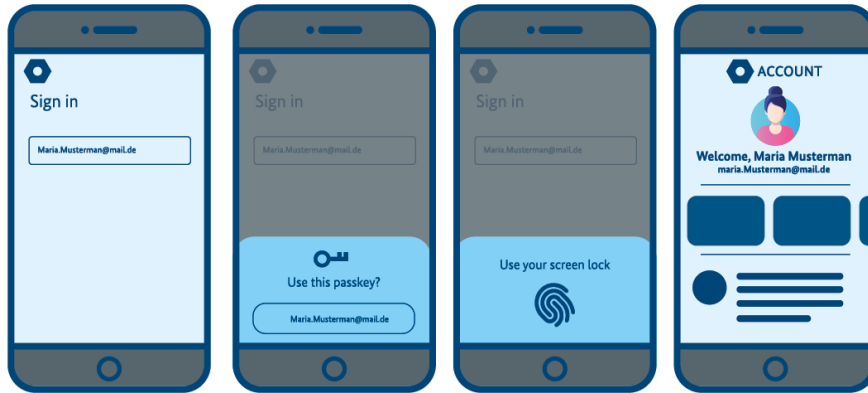
Nachteile

- Eine Mehrfaktor-Authentisierung verlängert den Anmeldevorgang geringfügig. Auf vertrauenswürdigen Geräten kann sie zwar unter Umständen übersprungen werden, dies verringert aber die Sicherheit.
- Wenn Sie keinen Zugriff auf Ihren besitzbasierten Faktor mehr haben oder er kaputt geht, verlieren Sie in der Regel den Zugang zum entsprechenden Dienst oder seine Funktionalität wird eingeschränkt. Sorgen Sie für diesen Fall vor, indem Sie – wenn möglich – mehrere "zweite Faktoren" hinterlegen (z.B. ein weiteres Token, eine weitere TAN-App oder eine weitere Mobiltelefonnummer für mTAN).

04

Passwordless

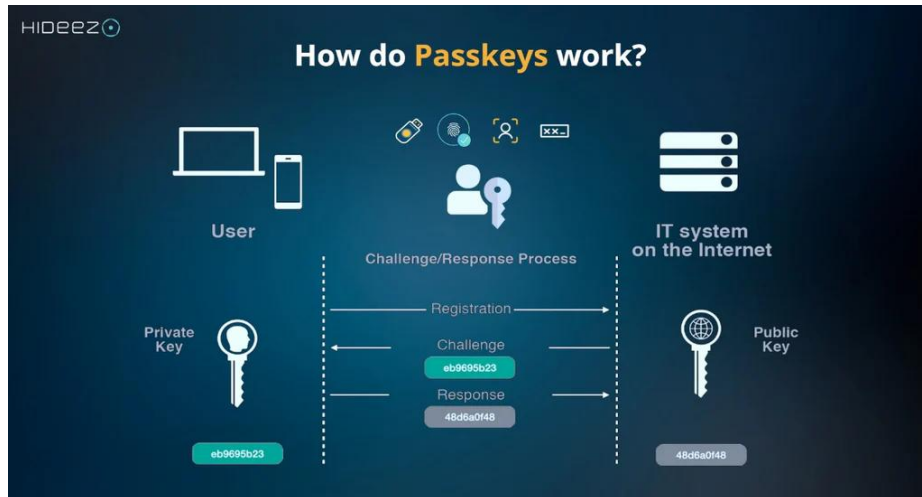
Wie funktioniert Passkey?



Wie funktioniert Passkey?

- 1. Schlüsselgenerierung:** Wenn Sie einen Passkey einrichten, erstellt Ihr Gerät (z.B. Ihr persönliches Smartphone, Tablet oder PC) ein einzigartiges Paar aus öffentlichem und privatem Schlüssel.
- 2. Speicherung des öffentlichen Schlüssels:** Der öffentliche Schlüssel wird an den Server der Website gesendet und dort gespeichert. Dieser Schlüssel allein kann nicht zum Anmelden verwendet werden.
- 3. Speicherung des privaten Schlüssels:** Der private Schlüssel wird sicher auf Ihrem Gerät gespeichert, oft in einem sicheren Enklave-Modul oder einem Trusted Platform Module (TPM).
- 4. Authentifizierungsprozess:** Wenn Sie sich anmelden möchten, sendet die Website eine Herausforderung an Ihr Gerät. Ihr Gerät verwendet den privaten Schlüssel, um diese Herausforderung zu signieren und eine einzigartige Signatur zu erstellen.
- 5. Verifizierung:** Die Website überprüft die Signatur mithilfe des gespeicherten öffentlichen Schlüssels und bestätigt Ihre Identität, ohne jemals Ihren privaten Schlüssel zu sehen.

Wie funktioniert Passkey?



Wie sicher ist die Anmeldung mit Passkey?

- Passkeys können **nicht zu simpel oder zu kurz** sein – Passwörter dagegen schon.
- Passkeys können im Gegensatz zu Passwörtern **nicht vergessen** werden.
- Passkeys werden **schnell und automatisiert** erstellt.
- Es ist unwahrscheinlicher, dass Passkeys durch **Phishing** oder **Datendiebstahl** verloren gehen.
- Jeder Passkey **schützt immer genau einen Account** – so können nie mehrere Accounts gefährdet sein, sollte ein Passkey missbraucht werden.

Vorteile:

- In Zukunft müssen **keine Passwörter mehr erstellt und verwaltet** werden
- **Immun gegen die breite Masse bekannter Phishing-Angriffe.** Denn selbst wenn eine Phishing-E-Mail dazu geführt hat, dass ein Anwender oder eine Anwenderin versucht, sich auf einer gefälschten Webseite einzuloggen, wird der geheime Schlüssel niemals preisgegeben.

05

Passwortmanager

47

IT-SICHERHEIT / SEMESTER 1 UND 2

Was ist ein Passwortmanager

- Ein Passwortmanager ist ein Online-Tool, mit dem **Benutzer ihre Passwörter erstellen, speichern, verwalten und verwenden** können, wann immer sie sie brauchen.
- Anstatt sich auf den persönlichen Speicher oder die Offline-Speicherung zu verlassen, die unsicher sein können, können die Benutzer ihre Passwörter **in einem verschlüsselten „Tresor“** speichern.
- Heutzutage erfordern viele Online- Dienste und Mitgliedschaften eine Anmeldung oder Registrierung. => **Dutzende von verschiedenen möglichen Passwörtern müssen gemerkt werden** – oder sich der Gefahr von „Passwortdiebstahl“-Angriffen aussetzen.
- Mit einem guten Passwortmanager können die Nutzer**
 - ihre sensiblen Daten speichern
 - ihre Passwörter von einem zentralen Dashboard aus ändern
 - und ihre Daten automatisch ausfüllen, um eine reibungslose Anmeldung zu ermöglichen.



48

Motivation für einen Passwort Manager

Schutz vor Datenverletzungen und Hacking-Angriffen

- Passwort-Manager ermöglichen es, starke, zufällige Passwörter für jeden Dienst zu generieren und zu speichern. Diese Passwörter sind schwer zu knacken und schützen Ihre Konten vor unbefugtem Zugriff.

Ein Passwort für alle: Ein Albtraum für die Sicherheit

- Passwort-Manager ermöglichen es Ihnen, eine Vielzahl von sicheren Passwörtern zu erstellen und zu verwalten, ohne sich jeden einzelnen merken zu müssen.

Komfort und Benutzerfreundlichkeit

- Passwort-Manager speichern Ihre Anmeldeinformationen sicher und ermöglichen es Ihnen, sich automatisch bei Ihren Konten anzumelden.

Unterstützung für starke Authentifizierung

- Viele Passwort-Manager bieten heute auch die Möglichkeit der Zwei-Faktor-Authentifizierung (2FA) oder der biometrischen Authentifizierung, wie Fingerabdruck oder Gesichtserkennung.

Synchronisierung über Geräte hinweg

- Moderne Passwort-Manager ermöglichen es Ihnen, Ihre Passwortdatenbank über verschiedene Geräte hinweg zu synchronisieren.

Die Bedeutung von Aktualität

- Passwort-Manager informieren Sie oft darüber, wenn es Zeit ist, ein Passwort zu ändern, um potenziellen Gefahren einen Schritt voraus zu sein.



[Quelle: <https://vaulteron.com/de/docs/warum-passwort-manager-wichtig-sind/> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

49

49

Was macht einen Passwort-Manager sicher?

- Multi-Faktor-Authentifizierung
- Generator für sichere Passwörter
- Sichere Synchronisierung
- Automatische Datenleck-Warnungen
- Browsererweiterungen
- Passwortverwaltung für Apps
- Digital Wallet
- Zugriff für Dritte im Notfall

Lokale Passwortmanager

Lokale Passwortmanager speichern die Nutzerdaten lokal auf dem Gerät, das der Kunde benutzt. Bei lokalen Passwort-Managern liegt die Verantwortung bei dem jeweiligen Unternehmen oder sogar bei der Einzelperson.

Cloudbasierte Passwort-Manager

Diese speichern die Nutzerdaten in der Cloud, so dass sie von jedem internetfähigen Gerät abgerufen werden können. Beispiele sind LastPass, 1Password, Dashlane und andere.

Passwort-Manager für Unternehmen

Auf große Unternehmen ausgerichtet. Sie bieten zusätzliche Funktionen, wie z. B. rollenbasierte Zugangskontrolle, und zusätzliche Sicherheitsebenen.



[Quelle: <https://www.avast.com/de-de/c-best-password-managers> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

50

50

Checkliste für die Auswahl eines Passwort-Managers

- Von E-Mail bis Social Media: **Für welche Konten** brauchen Sie einen Passwort-Manager?
- **Browser-basiert oder eigenständig:** Welches Programm passt am besten zu Ihren Online-Gewohnheiten?
- **Cloud oder Festplatte:** Wo werden Ihre Daten gesichert?
- **Sensible Daten:** Benötigen Sie einen zweiten Faktor zur Authentisierung?
- **Komplexe Kombinationen:** Haben Sie ein sicheres Masterpasswort?

Vorteile und Nachteile

Vorteile

- **Verwahren von Passwörtern** und Benutzernamen mittels Verschlüsselung
- **Unterstützung bei der Passwortvergabe**, z. B. durch die Generierung starker Kombinationen und Kennzeichnung schon verwendeter oder schwacher Begriffe.
- **Warnung vor gefährdeten Websites und möglichen Phishing-Attacken**, z. B. wenn sich die URL der aufgerufenen Webseite von der gespeicherten unterscheidet.
- **Synchronisieren möglich:** Wer Online-Dienste auf mehreren Geräten wie Computer und Smartphone mit unterschiedlichen Betriebssystemen nutzen möchte, kann ein Programm verwenden mit Sync Funktion.

Nachteile

- **Beim Vergessen des Masterpassworts sind im schlechtesten Fall alle Daten verloren.** Das bedeutet oftmals viel Arbeit, da die einzelnen Zugänge zu den Konten individuell wiederhergestellt werden müssen.
- **Alle Passwörter können auf einmal gestohlen werden**, sollte ein Cyber-Angriff auf einen Passwort-Manager erfolgreich sein.
- **Bei cloudbasierten Diensten vertrauen Sie den Zugang zu all Ihren sensiblen Daten in der Regel einem Unternehmen an.** Hier lohnt sich ein Blick in die AGB und Datenschutzerklärungen des jeweiligen Herstellers. Standort des Cloud-Dienste-Anbieters und der Server geben Auskunft darüber, welchem Datenschutzrecht die Daten unterliegen.

06

Schadsoftware

53

IT-SICHERHEIT / SEMESTER 1 UND 2

Übung – Cybersecurity Quiz, sicher vor Betrug schützen

<https://cybersecurityquiz.app.ovosplay.com/>



Erarbeite die Grundlagen zu Schadsoftware eigenständig.

Registriere dich auf: <https://cybersecurityquiz.app.ovosplay.com/>

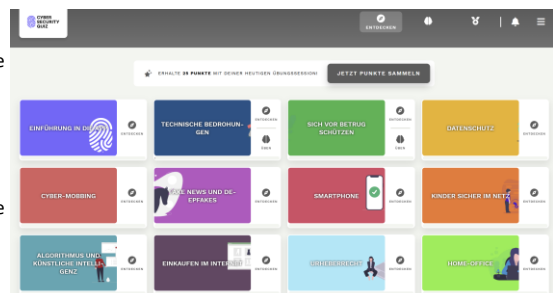
Dokumentiere das Ergebnis (Screenshot) als PDF auf Moodle

Teil 1: Entdecken

- Modul: Technische Bedrohungen
- Aufgabe: Einführung Schadsoftware
- Aufgabe: Szenarien Schadsoftware

Teil 2: Üben

- Modul: Technische Bedrohungen
- Aufgabe: Einführung Schadsoftware



54